INFORMATION SECURITY RISK POLICY

POL-010 | Issued under the Information Management Framework

Document ID: POL-010
Version: 1.0 — DRAFT
Parent Framework: IMF-001 — Information Management Framework
Classification: Internal Use
Owner: Chief Information Security Officer
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Information Security Risk Policy
Document ID	POL-010
Version	1.0 — DRAFT
Status	Draft for Review
Parent Framework	IMF-001 — Information Management Framework
Document Owner	Chief Information Security Officer (CISO)
Custodian	Information Security
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]
Regulatory Alignment	ISO/IEC 27001:2022 (Clause 6.1, 8.2–8.3), ISO 31000:2018, NIST SP 800-30, 21 CFR Part 11, EU Annex 11, GDPR Art. 32, SOX Section 404, GxP

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This Policy establishes the framework within which [Company Name] identifies, assesses, treats, and monitors information security risks — the risks that arise from the confidentiality, integrity, and availability of information and the systems that hold it.

Information security risk management is not an isolated compliance exercise. It is the mechanism that connects the threats facing [Company Name] to the controls that address them, and those controls to the policies in this IMF suite. Every control obligation in every policy — from data classification thresholds to access review frequencies to validation requirements — has a risk basis. This Policy makes that basis explicit and ensures the organisation's risk posture is governed, monitored, and reported coherently.

This Policy deliberately integrates with [Company Name]'s existing domain-specific risk processes — particularly the Data Integrity Risk Assessment (DIRA) programme under SOP-003, the system classification framework under POL-005, and the privacy risk (DPIA) process under SOP-004 — rather than replacing them. Those processes are domain-specific instances of the broader risk management framework defined here.

> **NOTE:** Risk management is not a documentation exercise. The purpose of the Risk Register, risk assessments, and risk treatment plans is to drive real decisions about where to invest in controls, where to accept residual risk, and how to escalate risks that exceed the organisation's tolerance. A Risk Register that is not actively used in decision-making is a compliance artefact, not a management tool.

2. Scope

This Policy applies to all information security risks — risks to the confidentiality, integrity, and availability of [Company Name]'s information assets, systems, and technology infrastructure. It covers risks arising from:

- Internal threats: human error, misuse, fraud, misconfiguration, and process failure
- External threats: cyberattack, ransomware, supply chain compromise, physical intrusion, and natural disaster
- Technology risk: system failure, unplanned downtime, inadequate change management, software vulnerabilities
- Regulatory compliance risk: failure to maintain GxP validated state, SOX ITGC control failure, GDPR breach, HIPAA violation — where these risks arise from information security failures
- Third-party risk: risks introduced by vendors, processors, and partners who access [Company Name] systems or hold [Company Name] data

This Policy applies to all employees, contractors, System Owners, and Data Owners. The scope of any individual risk assessment is determined by the classification of the assets and systems in scope.

3. Risk Appetite and Tolerance

Risk appetite is the amount and type of risk [Company Name] is willing to accept in pursuit of its business objectives. Risk tolerance is the acceptable variation around that appetite before escalation or treatment is required. Both are defined here by risk category — because a pharmaceutical company's tolerance for GxP data integrity risk is fundamentally different from its tolerance for website availability risk.

Risk Category	Appetite	Tolerance	Rationale
GxP Data Integrity Risk (patient safety, regulated records, audit trail integrity)	Near zero	No tolerance for deliberate falsification, audit trail manipulation, or validated system degradation. Unmitigated Critical risks must be resolved before the system is used for GxP activities. Residual risk of ≤ Low (score ≤ 3) is acceptable with documented mitigation.	Regulatory failure in GxP carries direct patient safety consequences and can result in product recalls, clinical trial invalidity, and loss of manufacturing or marketing authorisation. The regulatory cost of a GxP data integrity failure is existential.
Regulatory Compliance Risk (SOX ITGC failure, material weakness, GDPR enforcement action)	Very low	No tolerance for undetected material weaknesses in SOX ITGC controls. No tolerance for GDPR breaches involving Special Category or clinical trial participant data without prompt notification and remediation. Residual risk of ≤ Low–Medium (score ≤ 7) acceptable with documented treatment plan.	SOX material weaknesses trigger restatement risk and auditor adverse opinions. GDPR enforcement actions for Special Category data failures carry fines up to €20M or 4% of global turnover. These risks have direct financial and reputational consequences for a publicly traded company.
Data Confidentiality Risk (unauthorised disclosure of Sensitive or above classified data)	Low	Tier 4–5 data: no tolerance for uncontrolled disclosure. Tier 3: medium tolerance where technical controls are in	Disclosure of Highly Confidential or Sensitive Personal data carries regulatory, competitive, and reputational consequences. Clinical trial data and employee personal data are particularly sensitive.

Risk Category	Appetite	Tolerance	Rationale
		place. Residual risk of ≤ Medium (score ≤ 7) acceptable for Tier 3. Tier 4–5: residual risk must be ≤ Low (score ≤ 3).	
Operational Availability Risk (unplanned downtime for Tier 1/2 systems)	Low–Medium	Tier 1 systems: unplanned downtime > RPO/RTO targets triggers incident response and root cause analysis. Residual risk of ≤ Medium acceptable if BC/DR controls are in place. Tier 3/4: Medium–High tolerance.	Business continuity of critical systems is important but not at the same regulatory threshold as data integrity or regulatory compliance. Planned maintenance and controlled downtime are acceptable.
Information Security Operational Risk (vulnerabilities, patching gaps, configuration drift)	Medium	Critical and High vulnerabilities on Tier 1/2 and all GxP/SOX systems: patching or mitigating controls required within SLA (see Section 7). Medium vulnerabilities: treat within 90 days. Low: treat at next maintenance cycle or document risk acceptance.	A degree of operational security risk is unavoidable in a complex technology environment. The objective is timely treatment of high-impact risks, not zero vulnerability exposure.

GxP: Risk appetite is set by the CISO with Board / Audit Committee ratification. It is reviewed annually and whenever a material change in regulatory environment or business model occurs. Individual risk owners may not unilaterally accept risk that exceeds the defined tolerance for their risk category — escalation to CISO is required.

4. Risk Scoring Framework

Risk scores are calculated as Likelihood × Impact. The same 5×5 scale is used across all information security risk assessments at [Company Name] — including in the DIRA programme (SOP-003) and DPIA process (SOP-004). Consistency of scale enables direct comparison and aggregation of risks across domains.

4.1 Likelihood Scale

Score	Level	Definition
5	Almost Certain	Expected to occur in most circumstances — within the next 12 months without intervention. Known threat actor actively targeting this control area, or control has failed in this way before.
4	Likely	Will probably occur — reasonable chance within the next 1–2 years. Known vulnerability with known exploits; or control failure has been observed in similar organisations.
3	Possible	Might occur — plausible within the next 3 years. Theoretical threat with some evidence of occurrence in the industry.
2	Unlikely	Could occur but not expected — unlikely in the next 5 years. No known exploit for the specific vulnerability; threat actor would need significant resources.
1	Rare	May occur only in exceptional circumstances — horizon beyond 5 years or requiring a highly improbable combination of events.

4.2 Impact Scale

Score	Level	Definition — assess the HIGHEST applicable consequence
5	Critical	Patient safety impact OR loss of marketing / manufacturing authorisation OR regulatory enforcement action (import alert, consent decree) OR data breach involving >10,000 data subjects with Special Category data OR ransomware event paralysing operations >72 hours.
4	Major	Significant GxP data integrity failure requiring regulatory notification OR SOX material weakness with restatement risk OR GDPR enforcement action with >€1M fine OR unplanned Tier 1 system outage >24 hours OR loss of Highly Confidential data to unauthorised party.
3	Moderate	GxP non-compliance finding requiring CAPA without immediate regulatory notification OR SOX control deficiency without material weakness OR personal data breach (Tier 4) requiring supervisory authority notification OR unplanned Tier 1 system outage 4–24 hours.
2	Minor	Internal audit finding without regulatory consequence OR Tier 3 system

Score	Level	Definition — assess the HIGHEST applicable consequence
		outage OR limited data exposure without regulatory threshold breach OR security incident contained without data loss.
1	Negligible	No operational impact, no regulatory consequence, no data exposure. Nuisance-level event detectable only by monitoring.

4.3 Risk Rating Matrix

Risk Score	Rating	Required Response
20–25	Critical	Immediate escalation to CISO and senior leadership. Treatment plan required within 5 business days. For GxP systems: system may not be used for regulated activities until Critical risk is mitigated. Board / Audit Committee notification assessed.
12–19	High	Formal risk treatment plan required within 30 days. CISO approval for any risk acceptance. Reported at next ISSG meeting. For GxP systems: treatment plan required before or immediately after go-live.
6–11	Medium	Risk treatment plan required within 90 days. System Owner and Information Security agree treatment approach. Tracked in Risk Register. Reported to ISSG quarterly.
3–5	Low	Document and monitor. Risk Owner confirms treatment approach (accept with documented rationale, or add to remediation backlog). Reviewed annually.
1–2	Very Low	Accept with brief documented rationale. No formal treatment plan required. Annual review.

5. Risk Assessment Process

Risk assessments are conducted at two levels: system-level assessments (triggered by POL-005 classification events and POL-006 validation milestones) and programme-level assessments (the annual organisation-wide Information Security Risk Assessment). Domain-specific risk assessments — DIRAs (SOP-003) and DPIAs (SOP-004) — are subordinate instances of this framework and feed into the programme-level view.

5.1 System-Level Risk Assessment

A system-level risk assessment is conducted:

- For every new system prior to go-live, as part of the POL-006 assurance track requirements
- For Track A (GxP) systems: the DIRA (SOP-003) is the system-level risk assessment — it is scoped to data integrity risks and is a component of the Validation Master File
- For Tier 1 and Tier 2 systems without a GxP flag: a System Security Risk Assessment covering confidentiality, integrity, and availability risks is conducted prior to go-live and reviewed annually
- For any system following a Major Impact change (per POL-006 / POL-007): the risk assessment is updated to reflect the post-change state

System-level risk assessments are owned by the System Owner, conducted with Information Security input, and approved by Information Security (Tier 3/4) or CISO (Tier 1/2 and all GxP/SOX systems).

5.2 Annual Organisation-Wide Risk Assessment

Information Security coordinates an annual Information Security Risk Assessment (ISRA) covering the full scope of [Company Name]'s information assets and threat landscape. The ISRA is not a repeat of every system-level assessment — it takes a strategic view, identifying emerging threats, cross-system vulnerabilities, and aggregate risk exposures that individual system assessments may miss.

ISRA Step	Description	Responsible
1 — Asset scope confirmation	Confirm the current list of information assets in scope from the Corporate Asset Register and system inventory. Confirm that all Tier 1 and Tier 2 systems have current (≤ 3-year) system-level risk assessments.	Information Security
2 — Threat landscape review	Review the current threat landscape relevant to [Company Name]'s industry (pharmaceutical, life sciences): sector-specific threat intelligence, regulatory authority cyber alerts (FDA, MHRA, EMA), CISA advisories, peer company incidents reported publicly. Identify any new threat categories not covered in the	Information Security / CISO

ISRA Step	Description	Responsible
	current Risk Register.	
3 — Risk Register review	Review all open risks in the Risk Register: confirm risk scores remain current, confirm treatment plan status, identify risks that have been mitigated and can be closed, identify any risks whose scores have changed due to new threat intelligence or control failures.	Information Security / Risk Owners
4 — Gap analysis	Identify any information assets, systems, or business processes not covered by a current risk assessment. Prioritise gap coverage based on criticality tier and regulatory flag.	Information Security
5 — New risk identification	Based on threat landscape review and gap analysis, identify new risks for addition to the Risk Register. Score using the framework in Section 4.	Information Security / System Owners
6 — ISSG reporting	CISO presents the ISRA output to ISSG: updated Risk Register, changes in risk profile from prior year, Critical and High risks status, risk treatment programme status. ISSG approves risk treatment priorities for the coming year.	CISO / ISSG
7 — Board reporting	CISO provides an annual information security risk summary to the Board / Audit Committee: overall risk posture, material risks, treatment programme, any risks exceeding appetite that require Board-level risk acceptance.	CISO / Board

5.3 Trigger-Based Assessments

Risk assessments must be initiated outside the annual cycle when triggered by:

- A new or significantly changed system (Tier 1 or 2) or GxP system — prior to go-live per Section 5.1
- A Critical or High severity security incident (per POL-012) — risk assessment updated to reflect root cause within 30 days of incident closure
- A Critical or High data integrity incident (per SOP-003) — DIRA updated within 30 days
- A significant change in the regulatory landscape — new guidance from FDA, EMA, MHRA, ICO, or other relevant authority
- A significant organisational change — merger, acquisition, major new product line, new jurisdiction of operation
- A material third-party security incident affecting a vendor with access to [Company Name] systems or data (per POL-013)

6. Risk Treatment

Every risk in the Risk Register must have a documented treatment approach. The four treatment options below are available — the choice is made by the Risk Owner with Information Security input, subject to the escalation requirements in this Policy.

Treatment Option	Definition	When Applicable	Approval Required
Mitigate (reduce)	Implement controls that reduce the likelihood and/or impact of the risk to an acceptable level. The most common treatment for Medium and above risks.	Available for any risk where cost-effective technical or procedural controls exist. Technical mitigations must be implemented via POL-007 change management.	System Owner proposes; Information Security approves. CISO approval for controls on Tier 1/GxP/SOX systems.
Transfer (share)	Transfer financial consequence to a third party (e.g., cyber insurance) or contractually transfer responsibility to a vendor (e.g., DPA, BAA, SLA with penalty). Does not reduce the likelihood of the risk occurring — only the financial impact to [Company Name].	Appropriate complement to mitigation for residual financial impact, particularly for operational availability and breach notification cost risks. Cannot transfer GxP or SOX compliance obligations.	CISO approval. CFO involvement for insurance decisions. Legal / Compliance for contractual transfer.
Accept (retain)	Formally document the decision to accept the risk without further treatment. The risk is logged in the Risk Register with the Risk Owner's signed acceptance and the rationale.	Available for Low and Very Low risks, or where cost of treatment demonstrably exceeds the expected impact. Not available for any risk rated Critical or High in the GxP Data Integrity or Regulatory Compliance categories (per Section 3).	Risk Owner for Very Low. Information Security for Low. CISO for Medium. CISO + CIO for High. CISO + CIO + Board for any risk exceeding defined tolerance. GxP risks: Compliance / QA must be a co-acceptor.
Avoid (eliminate)	Eliminate the risk by stopping the activity that creates it — for example, deciding not to deploy a system, discontinuing a process, or not processing a category	Available when the risk cannot be reduced to an acceptable level at acceptable cost, and the activity creating the risk is not a core business requirement.	System Owner and CIO, with Compliance / QA for GxP-affecting decisions.

Treatment Option	Definition	When Applicable	Approval Required
	of data.		

6.1 Risk Treatment Plans

Every Critical, High, and Medium risk requires a documented Risk Treatment Plan. The plan must specify:

- The treatment option selected and rationale
- The specific controls to be implemented (for Mitigate)
- The Risk Owner accountable for treatment delivery
- Target completion date: Critical — 5 business days; High — 30 days; Medium — 90 days
- Interim mitigating controls in place while the treatment plan is executed
- Residual risk score after treatment is complete
- Verification method: how will the CISO confirm the treatment is effective?

Technical mitigations must be implemented via a POL-007 change request. The Risk Treatment Plan reference number is recorded in the change request to create a traceable link between the risk and the control change.

6.2 Vulnerability Management

Identified technical vulnerabilities — software, firmware, configuration weaknesses — are a subset of information security risk and are treated as follows:

Severity	System Scope	Patch / Mitigate SLA	Treatment If SLA Cannot Be Met
Critical (CVSS ≥ 9.0)	All systems	24 hours — emergency change via POL-007	Compensating control (network isolation, WAF rule, access restriction) within 24 hours. Patch as soon as feasible. CISO notification mandatory.
High (CVSS 7.0–8.9)	Tier 1, Tier 2, all GxP/SOX	7 days — normal or emergency change	Compensating control within 7 days. Patch within 30 days. Risk acceptance documented.
High (CVSS 7.0–8.9)	Tier 3, Tier 4	30 days	Risk acceptance if not patchable within 30 days. CISO notification.
Medium (CVSS 4.0–6.9)	Tier 1, Tier 2, all GxP/SOX	30 days	90-day extension with documented risk acceptance. CISO notification.
Medium	Tier 3, Tier 4	90 days	Risk acceptance with annual

Severity	System Scope	Patch / Mitigate SLA	Treatment If SLA Cannot Be Met
(CVSS 4.0–6.9)			review.
Low (CVSS < 4.0)	All systems	Next scheduled maintenance cycle	Document. Annual review.

IMPORTANT: For GxP systems: patching is a change under POL-007 and requires a validation impact assessment. An emergency patch on a GxP system resolves the security risk but may require re-testing before the system is confirmed as remaining in a validated state. The CISO and Head of Quality must agree the sequence when these obligations conflict — security typically takes precedence, with validation assessment completed within 5 business days.

7. Risk Register

The Risk Register is the authoritative record of all identified information security risks at [Company Name]. It is a live document, maintained by Information Security, and used as the primary input to ISSG risk governance discussions.

7.1 Risk Register Structure

Field	Description
Risk ID	Unique identifier (ISR-YYYY-NNN format)
Risk Title	Short descriptive name
Risk Description	Detailed description of the risk event, cause, and consequence
Risk Category	Category per Section 3 (GxP Data Integrity / Regulatory Compliance / Data Confidentiality / Operational Availability / IS Operational)
Affected Assets	Systems, data assets, or processes affected (referencing POL-005 asset classification)
Inherent Risk Score	Likelihood × Impact without any controls in place
Existing Controls	Controls currently in place that reduce inherent risk
Residual Risk Score	Likelihood × Impact with existing controls applied
Risk Rating	Critical / High / Medium / Low / Very Low per Section 4.3
Treatment Option	Mitigate / Transfer / Accept / Avoid
Treatment Plan	Reference to Treatment Plan document (for Critical/High/Medium)
Risk Owner	The individual accountable for the treatment decision and delivery
Target Completion	Target date for treatment plan completion
Current Status	Open / In Treatment / Accepted / Closed
Date Identified	Date risk was first entered in the Register
Last Reviewed	Date of most recent review of this risk entry
Linked Documents	References to DIRA, DPIA, audit findings, or incidents that identified or inform this risk

7.2 Risk Register Governance

Governance Activity	Frequency	Responsible
Update risk scores for open risks based on new intelligence or control changes	As needed / following incidents or	Information Security

Governance Activity	Frequency	Responsible
	assessments	
Review Critical and High risks — confirm treatment plans are on track	Monthly	CISO
Review all open risks — ISSG reporting	Quarterly	CISO → ISSG
Full Risk Register review — annual ISRA	Annual	Information Security / CISO
Report material risks to Board / Audit Committee	Annual (minimum); immediately for emerging Critical risks	CISO → Board
Confirm Risk Register is aligned with current DIRA Register (SOP-003)	Quarterly	Information Security / DIO
Archive closed risks (retain for 7 years)	On closure	Information Security

8. Relationship to Domain-Specific Risk Processes

This Policy governs the overarching information security risk framework. Several domain-specific risk processes exist within the IMF suite. These are not separate programmes — they are scoped instances of this framework applied to specific regulatory or technical domains. Their outputs feed into the Risk Register maintained under this Policy.

Domain Risk Process	Governing Document	Relationship to This Policy
Data Integrity Risk Assessment (DIRA)	SOP-003 — Data Integrity Process	DIRAs assess data integrity risks for GxP systems. They use the same 5×5 risk scoring matrix. DIRA Critical and High findings must be reflected in the organisation-wide Risk Register as GxP Data Integrity risks. The DIRA Register (maintained by the DIO) is a domain-specific sub-register of the Risk Register.
Data Protection Impact Assessment (DPIA)	SOP-004 — Privacy Process	DPIAs assess privacy risks for new or significantly changed personal data processing activities. DPIA High risks that cannot be mitigated to acceptable levels must be escalated to supervisory authority (GDPR Art. 36) and must also be reflected in the Risk Register as Regulatory Compliance risks. The DPO maintains the DPIA register; Information Security maintains alignment with the Risk Register.
Third-Party / Vendor	POL-013 — Third Party	Vendor risk assessments identify risks introduced by third-

Domain Risk Process	Governing Document	Relationship to This Policy
Risk Assessment	and Vendor Risk Policy	party access to [Company Name] systems or data. Material third-party risks (High or above) must be reflected in the Risk Register, owned by the Sponsor or relevant System Owner.
SOX ITGC Risk	POL-007, POL-008, POL-009	SOX ITGC control deficiencies identified during internal or external audit are treated as Regulatory Compliance risks in the Risk Register. Information Security provides the ITGC risk view; Compliance / QA provides the regulatory consequence assessment.
System Security Risk Assessment	POL-006 — Computer System Validation and Qualification Policy	System-level security risk assessments conducted as part of Track C/D qualification feed into the Risk Register for Tier 1/2 non-GxP systems. The System Owner is the Risk Owner for system-level risks.

9. Roles and Responsibilities

Three distinct accountabilities must not be conflated in risk management: the Risk Owner (accountable for the business decision to accept or treat the risk), the Control Owner (accountable for implementing the technical or procedural mitigations), and Information Security (accountable for the programme that identifies, assesses, and monitors all risks). Where one individual holds more than one of these roles for the same risk, a compensating review by an independent party is required.

Role	Responsibility
Board / Audit Committee	Sets and ratifies risk appetite annually. Reviews annual risk summary from CISO. Approves risk acceptance decisions that exceed defined tolerance. Provides oversight of the organisation's overall risk posture.
CISO	Owns this Policy and the Risk Register. Presents risk posture to ISSG quarterly and to Board annually. Approves all High and Critical risk treatment plans. Approves all risk acceptance decisions above Low. Sets vulnerability management SLAs. Coordinates the annual ISRA.
ISSG (Information Security Steering Group)	Governance body for all information security risk matters. Reviews Risk Register quarterly. Approves risk treatment programme priorities. Escalates material risks to Board. Receives DIO quarterly report (DIRA status) and DPO report (DPIA and breach status).
Information Security	Maintains the Risk Register. Conducts and coordinates risk assessments. Monitors vulnerability management programme. Supports Risk Owners with risk assessment methodology. Provides quarterly Risk Register summary to ISSG.
Risk Owner	The individual (typically a System Owner or Data Owner) who is accountable for the business risk and the decision to accept or treat it. Owns and drives the Risk Treatment Plan. Reports treatment progress to Information Security. Cannot unilaterally accept risk above their authorisation threshold.
System Owner / Data Owner	Typically the Risk Owner for risks in their system or data domain. Provides input to risk assessments for their systems. Implements technical mitigations via POL-007 change management.
Compliance / QA	Co-Risk Owner for all GxP Data Integrity risks. Must co-sign risk acceptance for GxP category risks. Maintains alignment between DIRA Register and IS Risk Register. Provides regulatory impact assessment for compliance risks.
DPO	Co-Risk Owner for all Regulatory Compliance risks arising from personal data processing. Maintains DPIA register. Ensures DPIA High risks are reflected in the IS Risk Register. Assesses regulatory notification obligations for privacy-related risks.
Data Integrity Officer	Maintains the DIRA Register. Ensures all DIRA Critical and High risks are reflected in the IS Risk Register. Reports DIRA programme status to ISSG quarterly.

10. Exceptions

Exceptions to this Policy — particularly the risk appetite statements in Section 3 and the treatment timelines in Sections 5 and 6 — require written approval. Exceptions must document: the specific requirement being deviated from, the business justification, the mitigating controls in place, the residual risk level, and the approver.

No exception may override the near-zero tolerance for GxP Data Integrity risks as defined in Section 3. GxP risks rated Critical or High may not be accepted — they must be treated. Where treatment is technically impossible within the required timeline, the system must not be used for GxP activities until the risk is reduced to the acceptable residual level.

11. Related Documents

Document ID	Title	Relationship
IMF-001	Information Management Framework	Parent framework; ISSG governance structure defined here
POL-003	Data Integrity Policy	GxP data integrity risk obligations; ALCOA+ failures are risk events in the GxP Data Integrity category
POL-005	System Classification Policy	System criticality tier and regulatory flags determine risk assessment scope and scoring context
POL-006	Computer System Validation and Qualification Policy	System-level risk assessments for Track A/C are pre-go-live requirements; DIRA is a VMF component
POL-007	Change Management Policy	All technical risk mitigations implemented via POL-007 change control; change records link to Risk Treatment Plan IDs
POL-008	Access Control Policy	Access control failures (e.g., excessive privilege, stale accounts) are assessed as IS Operational risks
POL-009	Privileged Access Management Policy	Compromised privileged accounts are Critical or High IS Operational risks; PAM controls are primary mitigations
POL-011	Business Continuity Policy	BC/DR plans address Operational Availability risks identified in the Risk Register
POL-012	Incident Response Policy	Security incidents create or escalate Risk Register entries; post-incident risk assessment is mandatory for High/Critical incidents

Document ID	Title	Relationship
POL-014	Audit Trail and Monitoring Policy	Audit trail gap or immutability failure is a Critical IS risk assessed under this Policy; monitoring programme findings (unexplained gaps, anomalous access patterns) generate Risk Register entries; the SIEM is the primary detection source for IS risk events
POL-015	IT Service Management and Operational Incident Policy	P1 operational incidents and recurring P2 incidents on Tier 1/2 systems are Operational Availability risks tracked in the IS Risk Register; Known Errors on Tier 1 systems are open risks requiring treatment
POL-013	Third Party and Vendor Risk Policy	Third-party risk assessments feed into the IS Risk Register; vendor risk is a distinct risk sub-category
EXC-001	Exception Management Policy and Register	Risk acceptance for residual IS risks is governed by this Policy and is distinct from exceptions; procedural exceptions to the risk management process itself are governed by EXC-001; High and Critical exceptions feed this Policy's Risk Register
SOP-003	Data Integrity Process	DIRA is the GxP domain-specific instance of this risk framework; DIRA Register is a sub-register of the IS Risk Register
SOP-004	Privacy Process	DPIA is the privacy domain-specific instance of this risk framework; DPIA High risks feed into the IS Risk Register
RACI-001	Roles, Responsibilities and Authorities	Risk management accountability across all domains

12. Definitions

Term	Definition
Inherent Risk	The level of risk present without any controls in place.
Information Security Risk Assessment (ISRA)	The annual organisation-wide assessment of all information security risks, conducted by Information Security and reported to ISSG and the Board.
Residual Risk	The level of risk remaining after existing controls are applied.
Risk Appetite	The amount and type of risk [Company Name] is willing to accept in pursuit of its objectives. Defined per category in Section 3.

Term	Definition
Risk Owner	The individual accountable for the business risk and for the decision to accept or treat it. Typically the System Owner or Data Owner for the affected asset.
Risk Register	The authoritative record of all identified information security risks at [Company Name], maintained by Information Security.
Risk Tolerance	The acceptable variation around the risk appetite before escalation or treatment is required.
Risk Treatment	The action taken to address a risk: Mitigate, Transfer, Accept, or Avoid.
Risk Treatment Plan	The documented plan for implementing a chosen risk treatment, including controls, owner, timeline, and verification method.
Vulnerability	A weakness in a system, process, or control that could be exploited by a threat to realise a risk.

— End of Document —

POL-010 v1.0 DRAFT | [Company Name] | CONFIDENTIAL

[Amendment Section] Threat Intelligence Programme

This section formalises the [Company Name] threat intelligence programme, addressing ISO 27001 A.5.7 and providing the structured threat intelligence inputs required by the NIS2 Art. 21(a) risk analysis obligation and the GOV-001 programme effectiveness framework. Threat intelligence must be integrated into the risk assessment process — a risk register that does not incorporate current threat actor behaviour, active CVEs, and sector-specific threat intelligence is not an adequate risk analysis for NIS2 purposes.

9.1 Programme Ownership and Governance

Owner: CISO. The threat intelligence programme is a sub-component of the information security risk programme owned by this policy.
Review forum: ISSG. Threat intelligence digest presented at each ISSG meeting (minimum quarterly). The digest covers: emerging threats relevant to [Company Name]'s sector and technology stack; newly published CVEs in the CISA KEV relevant to in-scope systems; any threat actor activity specifically targeting the pharmaceutical, biotech, or medical device sector; intelligence relevant to supply chain risk (attacks on key vendors or technology providers).

9.2 Mandatory Threat Intelligence Sources

The following sources are actively monitored by Information Security and integrated into the risk register update cycle. New relevant entries in any mandatory source must be reviewed within 5 business days of publication and assessed for inclusion in the IS risk register.
CISA KEV (Known Exploited Vulnerabilities Catalog): Mandatory. Every CISA KEV entry for a product in the [Company Name] technology estate triggers a vulnerability management action under POL-017. The KEV publication date starts the SLA clock (POL-017 Section 4). Information Security performs a KEV sweep against the technology asset register weekly.

ENISA Threat Landscape (ETL): Mandatory. Annual ENISA Threat Landscape report reviewed by CISO within 30 days of publication. Significant new threat categories from ETL are assessed for addition to the IS risk register.
Health-ISAC (H-ISAC): Mandatory (or equivalent sector ISAC where [Company Name] holds membership). Sector-specific threat intelligence focused on pharmaceutical, biotech, medical device, and healthcare organisations. TLP-marked intelligence handled per TLP protocol. ISAC briefings reviewed by Information Security Manager at minimum monthly.
Vendor security advisories: Mandatory for all Tier A and Tier B vendors. Vendor security bulletins for systems in the [Company Name] technology estate are monitored and assessed within the vulnerability management SLA in POL-017. Critical vendor advisories are escalated to the CISO within 24 hours of receipt.
NCSC (UK) / ENISA advisories: Recommended. National cyber security centre alerts and advisories for the UK (or equivalent for the primary EU jurisdiction). Reviewed by Information Security at minimum weekly. Critical alerts escalated to CISO immediately.
NVD / CVE database: National Vulnerability Database and CVE feeds for technologies in the [Company Name] estate. Automated integration with the vulnerability management scanner (POL-017) where technically feasible.

9.3 Intelligence-to-Risk Integration

Threat intelligence must feed into the IS risk register. This is not optional — a risk register that is not updated based on current threat intelligence does not satisfy NIS2 Art. 21(a). The integration process:
Weekly: Information Security reviews KEV updates and critical vendor advisories. Any new KEV entry against an in-scope system triggers a POL-017 action and updates the relevant risk register entry.
Quarterly: CISO prepares a threat intelligence digest for the ISSG meeting. The digest includes: top 5 threats assessed as most relevant to [Company Name] in the current quarter; any threat actor activity targeting the sector; supply chain intelligence; any intelligence relevant to open High or Critical risks in the risk register. ISSG reviews whether any risk register entries should be re-scored in light of the intelligence.
Annual: Annual IS risk assessment (SOP-010) incorporates the year's threat intelligence as a baseline input. The CISO includes a threat landscape section in the Annual Programme Effectiveness Report (GOV-001 Section 4.2) summarising the key threat trends and how the risk register reflects them.

9.4 Annual Threat Intelligence Programme Review

The threat intelligence programme is reviewed annually as part of the POL-010 annual review. The review assesses: whether the mandatory sources remain appropriate; whether any new sources should be added (new sector ISACs, regulatory intelligence feeds, commercial threat intelligence subscriptions); whether the programme has been operating as designed (ISSG digests produced on time; risk register updated following intelligence inputs); and whether the programme has added value — were there risks identified through intelligence that would not have been found through vulnerability scanning alone? The review outcome is documented in the annual review record.